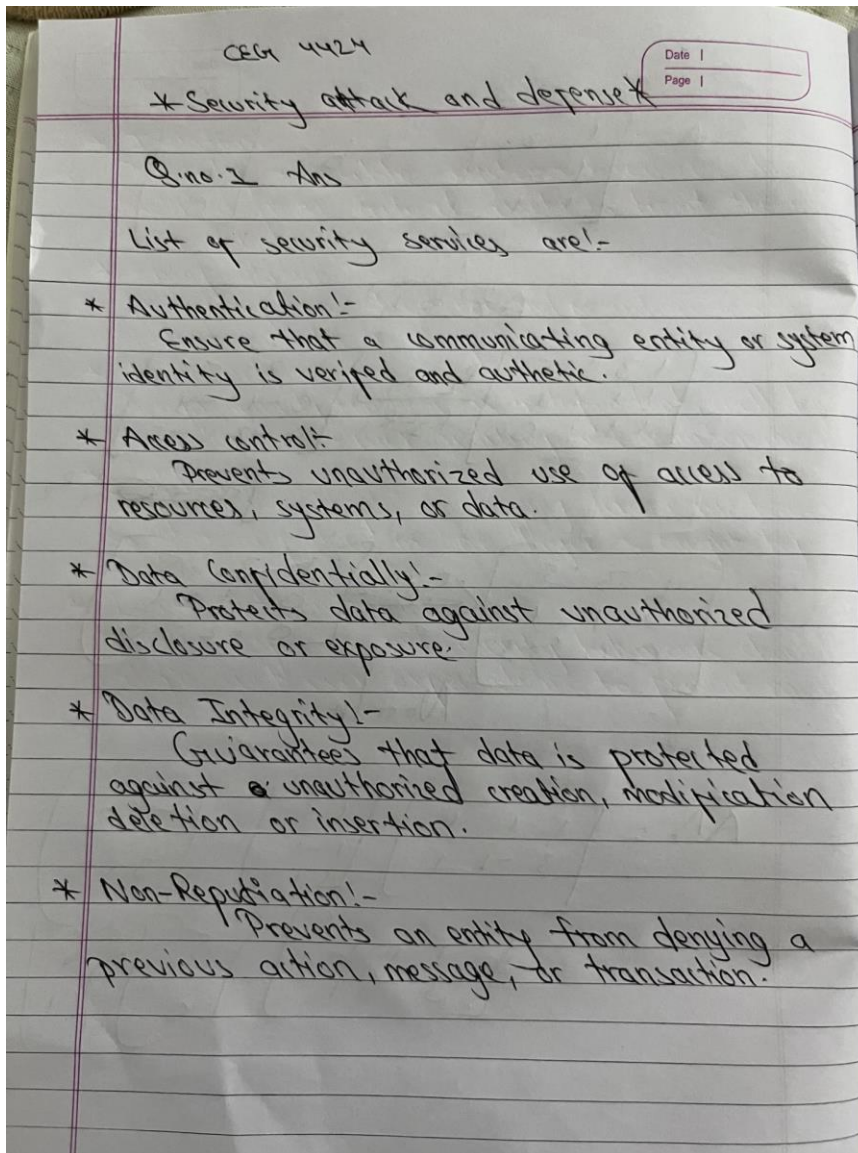


CEG 4424/6424 (Security Attacks and Defenses) Homework #1

Question 1 (10 points)

List and briefly define categories of security services.

Answer:



Question 2 (15 points)

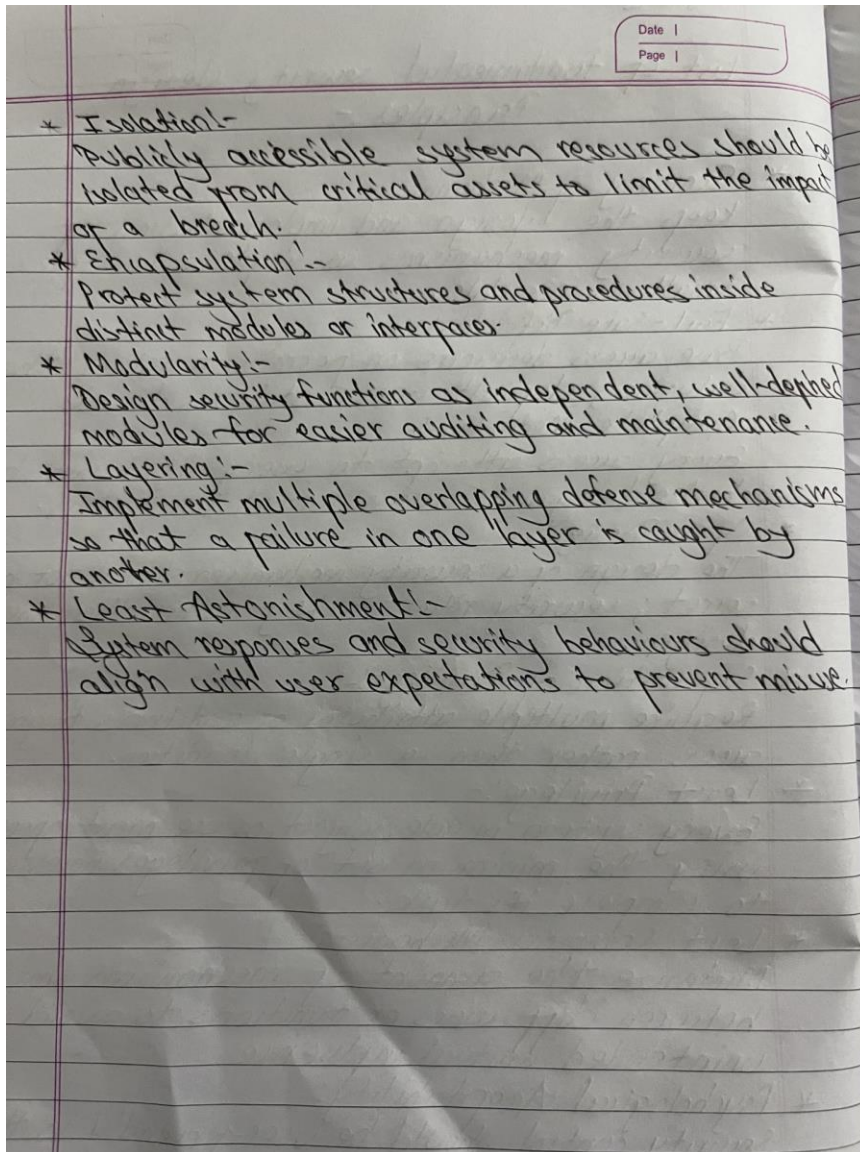
List and briefly define the fundamental security design principles.

Answer:

Q no 2

List of fundamental security design Principles:-

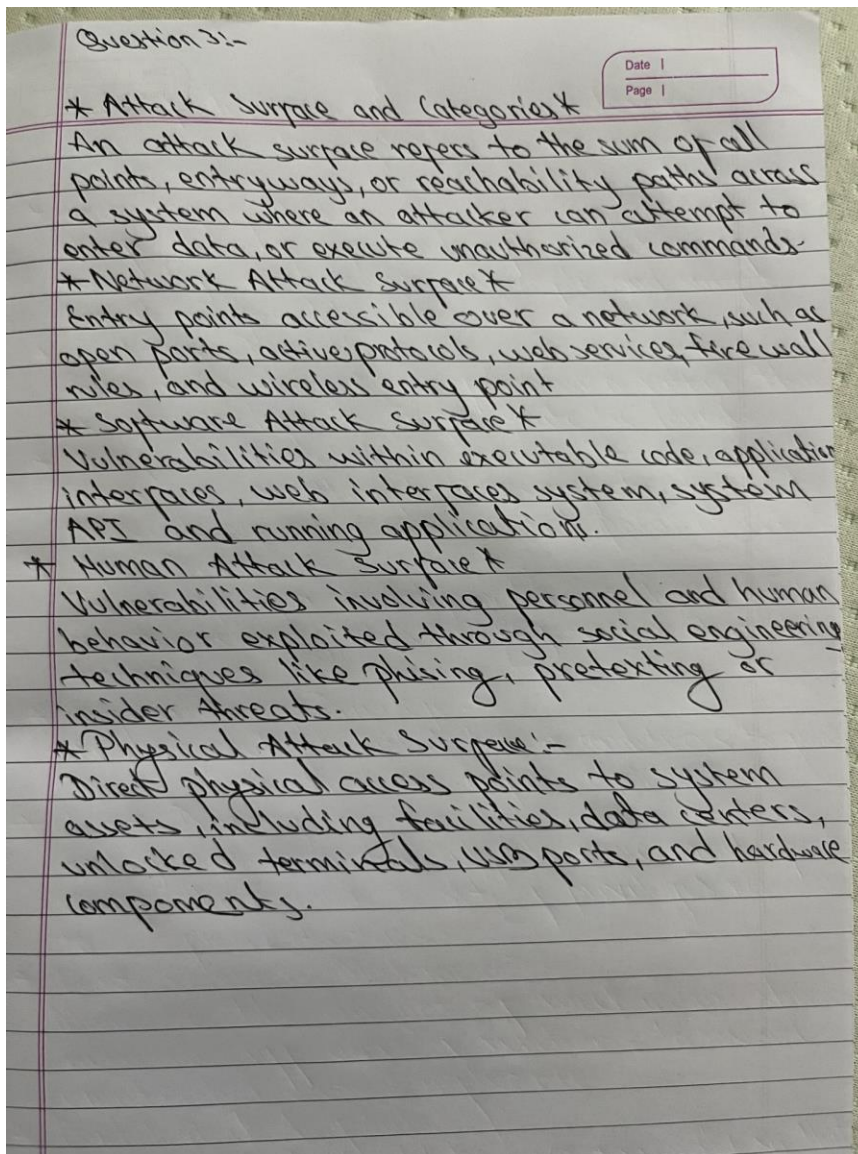
- * Economy of Mechanism:-
Keep the design and implementation of security mechanisms as simple and simple small as possible.
- * Fail-Safe Defaults:-
Base access decisions on permission rather than exclusion; default access state is denial.
- * Complete Mediation:-
Every access attempt to every object must be checked against access control parameters.
- * Open Design:-
The design of a security mechanism should not be secret; security relies on key rather than obscure designs.
- * Separation of Privilege:-
Require multiple attributes or conditions to grant access rather than a single condition.
- * Least Privilege:-
Every system module, subject, or user must operate using the minimum set of privileges necessary to complete its task.
- * Least Common Mechanism:-
Minimize the amount of mechanisms shared between diff users or functions to avoid unintended mutual influence.
- * Psychological Acceptability:-
Security control should be user-friendly so that user do not bypass or disable them.



Question 3 (10 points)

What is an attack surface? What are the categories of attack surface?

Answer:



Question 4 (5 points)

What is an attack tree?

Answer:

An attack tree is a structured diagram representing potential attack paths against a system. It places the ultimate goal of the attacker as the root node at the top, while lower branches and leaf nodes detail the sub-goals and specific techniques required to accomplish that primary objective.

Question 5 (30 points) Considering the following assignment of clearance/classification levels for both subjects and objects.

Clearance/Classification Level	Subject	Object
High	Administor	System Configuration

Medium	Regular User	User Configuration
Low	Guest	Temporal File

- a. Fill out all cells for the access control matrix if a system uses Bell-LaPadula Model. If the subject has “read” access to the object, you can put “r” in that cell. If the subject has “write” access to the object, you can put “w” in that cell. For instance, if A can “read” and “write” the object B, you can put “r,w” into the cell corresponding to (A, B).

	System Configuration	User Configuration	Temporal File
Administrator	r, w	r	r
Regular User	w	r, w	r
Guest	w	w	r, w

- b. Fill out all cells for the access control matrix if a system uses Biba Model. If the subject has “read” access to the object, you can put “r” in that cell. If the subject has “write” access to the object, you can put “w” in that cell. For instance, if A can “read” and “write” the object B, you can put “r,w” into the cell corresponding to (A, B).

	System Configuration	User Configuration	Temporal File
Administor	r, w	w	w
Regular User	r	r, w	w
Guest	r	r	r, w

- c. Fill out all cells for the access control matrix if the system uses Low-Water Mark policy after the administor reads the “Temporal File”.

	System Configuration	User Configuration	Temporal File
Administor	r	r	r, w
Regular User	r	r, w	w
Guest	r	r	r, w

Question 6 (10 points). The Common Vulnerabilities and Exposures (CVE) system provides a reference method for publicly known information-security vulnerabilities and exposures. Please describe what is CVE-2019-1125, CVE-2014-2915, CVE-2006-6893. (Hint: Please go to the website cve.mitre.org to find the descriptions of these CVEs. You should describe the content in your own words by rephrasing the sentences from the online resources.)

Answer:

CVE Descriptions

- **CVE-2019-1125:** A flaw in x86-64 processors related to speculative execution. It lets an attacker exploit timing variations caused by system interrupts to leak sensitive kernel memory contents.
- **CVE-2014-2915:** A vulnerability in the Xen hypervisor running on ARM architectures. Xen fails to properly restrict guest access to hardware features like cache controls, coprocessors, and debug registers, allowing a local guest VM to trigger a host or guest system to crash.
- **CVE-2006-6893:** A side-channel attack affecting the Tor network. An attacker can flood a Tor hidden service with traffic to raise its CPU temperature, introducing subtle timing shifts in network timestamps that reveal the server's actual IP address.